# Integration Scoping Plan: Halden Outfitters (FICTIONAL CUSTOMER)

**Goal:** A board-ready cyber risk figure within 30 days of kickoff.

**Prepared:** Nov 5, 2026 · **Status:** Draft for customer review

**Sources:** SAFE public integrations page (captured Nov 4, 2026); vendor API docs listed under each tool. Anything not found in those sources is marked **Confirm**.

---

## 1. Coverage check

| Customer tool | Bucket | Why |
|---|---|---|
| Okta | Out of the box | Exact match: "Okta" on SAFE's list ("Okta via M365" is also listed) |
| Tenable VM | Out of the box | Alias match: "Tenable VM" is configured as "Tenable Vulnerability Management" (config/aliases.json), which is on SAFE's list |
| CrowdStrike Falcon | Out of the box | Exact match: "CrowdStrike Falcon" on SAFE's list (related card also listed: "Crowdstrike Falcon Exposure Management (Spotlight)") |
| ServiceNow ITSM | Out of the box | Exact match: "ServiceNow ITSM" on SAFE's list |
| Microsoft Defender | Confirm with SAFE | No card named "Microsoft Defender". 5 cards on SAFE's list contain "defender": Microsoft 365 Defender, Microsoft Defender for Endpoints, Microsoft Defender for Identity via M365, Azure Defender for Cloud, Defender for Endpoint via M365. Need the exact product the customer licenses. |
| Snyk | Custom work | Not on SAFE's public list (105 cards). SAFE claims more integrations than it lists publicly, so Confirm with SAFE before scoping a build. |

## 2. Connection order (draft rules, editable)

1. **Tenable VM and CrowdStrike Falcon:** Shows which assets you have and which vulnerabilities they carry. The rest of the work depends on this.
2. **Okta:** Shows who can access which systems.
3. **ServiceNow ITSM:** Shows where fixes are tracked once priorities are set.
4. **Microsoft Defender:** Shows which assets you have and which vulnerabilities they carry. The rest of the work depends on this. Connect after the exact product is confirmed.
5. **Snyk:** Adds more findings that sharpen the overall view. Connect after SAFE confirms whether a connector exists.

*Ordering rules come from a config file, not the model. **Confirm** against SAFE's onboarding playbook.*

## 3. Access checklist

| Tool | What we need | Customer owner | Source |
|---|---|---|---|
| Okta | How we connect: Okta accepts an API token sent in the `Authorization` header with the prefix `SSWS`. It also accepts an OAuth access token sent in the same header with the prefix `Bearer`. Permissions or scopes: With OAuth, read access uses these scopes: `okta.users.read`, `okta.groups.read`, `okta.apps.read`, `okta.devices.read`, `okta.logs.read`, `okta.roles.read` and `okta.idps.read`. The sources do not name the admin role an API token needs. Confirm. | Okta administrator | Okta Management OpenAPI v2026.42.1, lines 100424, 100429; Okta Management OpenAPI v2026.42.1, lines 2004, 11809, 14115, 15596, 18828, 19732, 27061 |
| Tenable VM (Tenable Vulnerability Management) | How we connect: We connect with an API access key and secret key, sent in the `X-APIKeys` header as `accessKey` and `secretKey` values, to `https://cloud.tenable.com`. Keys are generated per user account. Tenable recommends a unique user account for each | Vulnerability management lead | Tenable VM API notes (developer.tenable.com), lines 7, 8, 43; Tenable VM API notes |

| Tool | What we need | Customer owner | Source |
|---|---|---|---|
| | API integration. Permissions or scopes: Vulnerability export needs the Basic [16] role or the custom privilege VM.VM_EXPLORE.VM_EXPLORE.EXPORT. The account also needs Can View access on the exported assets, which the All Assets object can grant. Administrator [64] users do not need Can View. The permission for asset export is not stated in the sources. Confirm. | | (developer.tenable.com), line 14 |
| CrowdStrike Falcon | How we connect: **Confirm.** No vendor docs on file for this tool, so nothing is guessed. Permissions or scopes: **Confirm.** No vendor docs on file for this tool, so nothing is guessed. | Endpoint security (EDR) administrator | None (no vendor docs on file) |
| ServiceNow ITSM | How we connect: **Confirm.** No vendor docs on file for this tool, so nothing is guessed. Permissions or scopes: **Confirm.** No vendor docs on file for this tool, so nothing is guessed. | ServiceNow administrator | None (no vendor docs on file) |
| Microsoft Defender | How we connect: **Confirm.** Waiting on the exact product the customer licenses. Permissions or scopes: **Confirm.** Waiting on the exact product the customer licenses. | Microsoft security administrator | None (no vendor docs on file) |
| Snyk | How we connect: We connect with a Snyk service account token, sent in the Authorization: token header. Snyk recommends service accounts for any automation. API access requires the Snyk Enterprise plan. Tokens are region-specific. Permissions or scopes: **Confirm.** The attached sources do not state this. | Application security lead | Snyk docs: Authentication for API, lines 13, 22, 44; Snyk docs: About the REST API, line 20 |

*For out-of-the-box connectors, SAFE's connector documentation decides the exact access needed. The access details above are what each vendor documents; confirm them with SAFE.*

## 4. Custom work scoping sheet: Snyk

*Snyk is not on SAFE's public list. **Confirm** with SAFE whether a connector exists before building one.*

| Item | Detail | Source |
|---|---|---|
| Base URL | Use the base URL for the account's region: https://api.snyk.io/rest (SNYK-US-01), https://api.us.snyk.io/rest (SNYK-US-02), https://api.eu.snyk.io/rest (SNYK-EU-01) or https://api.au.snyk.io/rest (SNYK-AU-01). | Snyk docs: About the REST API, line 18 |
| Versioning | Requests carry the version query parameter, a date in YYYY-MM-DD format. Snyk recommends 2024-10-15. Deprecated endpoints return a Sunset header with the date support ends. | Snyk REST OpenAPI spec, line 76026; Snyk docs: About the REST API, lines 56, 84 |
| Authentication | Send the token in the Authorization: token header. Requests that contain data also need Content-Type: application/vnd.api+json. A token used against another region's base URL returns 401 Unauthorized. | Snyk docs: Authentication for API, line 44; Snyk docs: About the REST API, lines 20, 33 |
| Endpoints | Organizations: /orgs. Projects: /orgs/{org_id}/projects. Targets: /orgs/{org_id}/targets. Issues: /orgs/{org_id}/issues, or /groups/{group_id}/issues for a group. Assets: /orgs/{org_id}/inventory/assets. All are read requests. | Snyk REST OpenAPI spec, lines 35290, 62402, 73993, 76022, 80094, 85213 |
| Useful filters | On /orgs/{org_id}/issues, updated_after and created_after limit results by time. effective_severity_level, status, type and ignored narrow the results further. | Snyk REST OpenAPI spec, lines 76022, 76055, 76067, 76085, 76094, 76097, 76100 |
| Pagination | Pagination is cursor-based. Responses include links that carry starting_after or ending_before cursors. limit sets the number of records per page. If the sort parameter is used, consistent pagination is no longer guaranteed. | Snyk docs: About the REST API, lines 94, 110, 111, 112 |
| Rate limits | The limit is 1620 requests per minute per API key. Requests above the limit get status 429 until requests stop for one minute. Snyk may add new rate limits. | Snyk docs: About the REST API, line 135 |

| Item | Detail | Source |
|---|---|---|
| Fields to map | From `/orgs/{org_id}/issues`: `id` maps to `finding_id`, `attributes.title` to `title`, `attributes.type` to `type`, `attributes.effective_severity_level` to `severity`, `attributes.status` to `status`, and `attributes.created_at` to `first_seen`. The field that links an issue to an asset is not confirmed. | Snyk REST OpenAPI spec, lines 17815, 18341, 18353, 18442, 18450, 18464, 76022; Our common format (config), lines 17, 19, 20, 21, 22, 23 |
| How records relate to assets | **Confirm.** Needs input from the customer. | None |

## 5. Data checks before anything feeds a risk number

- **Counts:** Asset and finding totals match what each tool's own console shows.
- **Duplicates:** The same machine seen by more than one tool is merged once, with the reason and a confidence level for each match. Weak matches go to a person to review.
- **Staleness:** Assets not seen within the customer's agreed window are flagged.
- **Coverage:** Share of assets with an endpoint agent; share scanned recently.
- **Orphan findings:** Findings that point to an asset no tool reports are flagged.
- **Tenable Vulnerability Management:** Without a time filter, a vulnerability export only includes vulnerabilities found or fixed in the last 30 days. We will set a time filter to match the agreed lookback. (Tenable VM API notes (developer.tenable.com), line 21)
- **Okta:** Okta device records from `/api/v1/devices` include `profile.serialNumber`, which maps to `serial_number` and can help match the same device across tools. (Okta Management OpenAPI v2026.42.1, lines 11678, 76903; Our common format (config), line 10)

## 6. Open questions for Halden Outfitters

1. SAFE also lists "Crowdstrike Falcon Exposure Management (Spotlight)". Do you use it in addition to CrowdStrike Falcon?
2. Which Microsoft Defender product do you license? SAFE lists these: Microsoft 365 Defender, Microsoft Defender for Endpoints, Microsoft Defender for Identity via M365, Azure Defender for Cloud, and Defender for Endpoint via M365.
3. For each tool, who owns the admin account, and who approves API access?
4. Which systems hold your most critical data or drive the most revenue? Your answer decides what counts first in the risk figure.
5. How far back should vulnerability history go? After how many days without being seen should an asset be treated as stale?
6. Do you have an existing asset inventory, such as a CMDB, that we should treat as the source of truth?
7. Are you on the Snyk Enterprise plan, and which Snyk region is your account in? API access needs the Enterprise plan, and a token only works in its own region.
8. Can you create a dedicated Tenable user account for this integration? Tenable recommends a unique user account for each API integration, and allows one valid API key per user at a time.

---

*Fictional customer. Built from public documentation only. SAFE's internal connector list and scoping template would replace the public versions used here.*